

Auth & Session Security Analyzer

Rapport d'audit de securite Android

Application analysee : app-debug
Type d'authentification : SESSION_COOKIE
Vulnerabilites detectees : 82
Date d'analyse : 18/05/2026 01:17

Score global de securite : 0 / 10 (CRITIQUE)

1. Resume Executif

Ce resume presente les principales vulnerabilites identifiees lors de l'audit, evalue le niveau de risque global et formule les recommandations prioritaires.

L'application Android de banque mobile analysée implémente un système d'authentification JWT présentant des vulnérabilités critiques mettant en danger direct la sécurité des utilisateurs et de leurs données financières. Les findings révèlent l'absence totale de contrôles d'authentification (score AUTH 0/10), des secrets et identifiants en dur dans le code source, l'enregistrement de credentials en clair dans les logs, et l'utilisation systématique du protocole HTTP non chiffré pour les communications sensibles. Le niveau de risque global est CRITIQUE : les tokens JWT ne disposent pas de mécanisme d'expiration, aucune blacklist de déconnexion n'est implémentée, et les tokens non chiffrés en storage peuvent être extraits facilement, permettant aux attaquants un accès illimité aux comptes utilisateurs et aux ressources financières. Les trois actions prioritaires sont : (1) migrer immédiatement vers HTTPS exclusif avec TLS 1.2+ et implémenter la validation cryptographique des tokens JWT, (2) supprimer tous les secrets du code source, chiffrer les tokens stockés avec EncryptedSharedPreferences, et implémenter une liste noire de tokens avec déconnexion effective, et (3) mettre en place une stratégie de rotation de tokens (access token court terme / refresh token long terme) et activer les logs sécurisés sans exposition de données sensibles.

2. Analyse Statique - Vulnerabilites detectees

L'analyse statique consiste en la decompilation de l'APK avec JADX et l'examen des sources Java/Kotlin par patterns regex. Les resultats sont classes par severite : CRITIQUE (-3 pts), ELEVE (-2 pts), MOYEN (-1 pt).

Fichiers analyses : 2918 | Vulnerabilites : 42 | Score : 0/10

Severite	Type	Fichier	Detail
CRITIQUE	Secret code en dur	AccessibilityNodeInfoCo...	password: "); builder.append(isPassword()); builder.app...
CRITIQUE	Secret code en dur	ChangePassword.java	password=" + this.uname); this.textView_Username = (Text...
ELEVE	Identifiants dans les logs	DoLogin.java	Log.d("Successful Login:", ", account=" + DoLogin.this.username ...
ELEVE	Hachage MD5 faible	zza.java	MessageDigest.getInstance("MD5"
MOYEN	Communication en clair (HTTP)	AnalyticsReceiver.java	http://g
MOYEN	Communication en clair (HTTP)	CampaignTrackingRecei...	http://g
MOYEN	Communication en clair (HTTP)	CampaignTrackingRecei...	http://g
MOYEN	Communication en clair (HTTP)	Tracker.java	http://h
MOYEN	Communication en clair (HTTP)	zza.java	http://g
MOYEN	Communication en clair (HTTP)	zzl.java	http://g
MOYEN	Communication en clair (HTTP)	zzl.java	http://g
MOYEN	Communication en clair (HTTP)	zzl.java	http://g
MOYEN	Communication en clair (HTTP)	zzl.java	http://g
MOYEN	Communication en clair (HTTP)	zzl.java	http://g
MOYEN	Communication en clair (HTTP)	zzl.java	http://g
MOYEN	Communication en clair (HTTP)	zzl.java	http://g
MOYEN	Communication en clair (HTTP)	zzl.java	http://g

MOYEN	Communication en clair (HTTP)	zzy.java	http://w
MOYEN	Communication en clair (HTTP)	Action.java	http://s
MOYEN	Communication en clair (HTTP)	Action.java	http://s
MOYEN	Communication en clair (HTTP)	Action.java	http://s
MOYEN	Communication en clair (HTTP)	Action.java	http://s
MOYEN	Communication en clair (HTTP)	Action.java	http://s
MOYEN	Communication en clair (HTTP)	Action.java	http://s
MOYEN	Communication en clair (HTTP)	Action.java	http://s
MOYEN	Communication en clair (HTTP)	Action.java	http://s
MOYEN	Communication en clair (HTTP)	Action.java	http://s
MOYEN	Communication en clair (HTTP)	Action.java	http://s
MOYEN	Communication en clair (HTTP)	Action.java	http://s
MOYEN	Communication en clair (HTTP)	Action.java	http://s
MOYEN	Communication en clair (HTTP)	Action.java	http://s
MOYEN	Communication en clair (HTTP)	Action.java	http://s
MOYEN	Communication en clair (HTTP)	Action.java	http://s
MOYEN	Communication en clair (HTTP)	Action.java	http://s
MOYEN	Communication en clair (HTTP)	Action.java	http://s
MOYEN	Communication en clair (HTTP)	Action.java	http://s
MOYEN	Communication en clair (HTTP)	Action.java	http://s
MOYEN	Communication en clair (HTTP)	zzm.java	http://p
ELEVE	Hachage MD5 faible	zzak.java	MessageDigest.getInstance("MD5"
ELEVE	Hachage MD5 faible	zzbl.java	MessageDigest.getInstance("MD5"
MOYEN	Communication en clair (HTTP)	zzgk.java	http://w
ELEVE	Hachage MD5 faible	zzhl.java	MessageDigest.getInstance("MD5"
MOYEN	Communication en clair (HTTP)	PlusOneButton.java	http://s
MOYEN	Communication en clair (HTTP)	PlusOneButton.java	http://s
MOYEN	Communication en clair (HTTP)	zzax.java	http://h

3. Analyse Dynamique - Tests d'authentification

L'analyse dynamique evalue le comportement de l'application en cours d'exécution. Les tests portent sur la validité des tokens après déconnexion, la durée de vie, la rotation des tokens, la fixation de session et la robustesse du mécanisme d'authentification.

Mode d'analyse : ERREUR

Déconnexion effective : Non testé

Durée de vie du token : None min

Rotation des refresh tokens : Non testé

Vulnérabilités détectées lors des tests :

INFO	HTTPConnectionPool(host='localhost', port=8888): Max retries exceeded with url: / (Caused by Ne
------	---

4. Cookie Security Scanner (OWASP)

Analyse des headers HTTP Set-Cookie interceptes via mitmproxy. Verification des 7 controles OWASP : flag HttpOnly (MASVS-NETWORK-2), flag Secure (MASVS-NETWORK-1), attribut SameSite (protection CSRF), Max-Age/Expires, restriction de domaine et prefixes __Host-/ __Secure-.

Cookies interceptes : 0 | Findings : 0 | Score : 10.0/10

Aucun cookie intercepte. Verifier que le proxy mitmproxy est actif lors de l'analyse dynamique.

5. Android Storage Scanner (SharedPreferences / Keystore)

Audit du stockage des donnees sensibles dans le code source decompile. Verification de l'usage de Android Keystore, EncryptedSharedPreferences, et detection des tokens stockes en clair (MASVS-STORAGE-1 et STORAGE-2).

Findings : 38 | Score : 0/10 | EncryptedSharedPreferences : NON | Android Keystore : NON

EncryptedSharedPreferences	NON
Android Keystore	NON

Severite	Type	Fichier	Fix recommande
ELEVE	Données sensibles dans les logs	FragmentManagerImpl...	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	FragmentManagerImpl...	Supprimer tout Log contenant des données d'auth en production (Build...
CRITIQUE	Écriture sur stockage externe	ContextCompat.java	Utiliser uniquement le stockage interne (getFilesDir).
CRITIQUE	Écriture sur stockage externe	ContextCompat.java	Utiliser uniquement le stockage interne (getFilesDir).
CRITIQUE	Écriture sur stockage externe	ContextCompat.java	Utiliser uniquement le stockage interne (getFilesDir).
CRITIQUE	Écriture sur stockage externe	ContextCompat.java	Utiliser uniquement le stockage interne (getFilesDir).
CRITIQUE	Écriture sur stockage externe	ContextCompat.java	Utiliser uniquement le stockage interne (getFilesDir).
CRITIQUE	Écriture sur stockage externe	ContextCompat.java	Utiliser uniquement le stockage interne (getFilesDir).
CRITIQUE	Écriture sur stockage externe	ContextCompatFroyo.j...	Utiliser uniquement le stockage interne (getFilesDir).
CRITIQUE	Écriture sur stockage externe	ContextCompatFroyo.j...	Utiliser uniquement le stockage interne (getFilesDir).
CRITIQUE	Écriture sur stockage externe	ContextCompatKitKat.j...	Utiliser uniquement le stockage interne (getFilesDir).
CRITIQUE	Écriture sur stockage externe	ContextCompatKitKat.j...	Utiliser uniquement le stockage interne (getFilesDir).
CRITIQUE	Écriture sur stockage externe	FileProvider.java	Utiliser uniquement le stockage interne (getFilesDir).
CRITIQUE	Écriture sur stockage externe	EnvironmentCompat.java	Utiliser uniquement le stockage interne (getFilesDir).
ELEVE	Données sensibles dans les logs	SpinnerCompat.java	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	SpinnerCompat.java	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	SpinnerCompat.java	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	SpinnerCompat.java	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	RegisteredMediaRoute...	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	RemotePlaybackClient...	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	RemotePlaybackClient...	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	RemotePlaybackClient...	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	RemotePlaybackClient...	Supprimer tout Log contenant des données d'auth en production (Build...

ELEVE	Données sensibles dans les logs	DoLogin.java	Supprimer tout Log contenant des données d'auth en production (Build...
CRITIQUE	Écriture sur stockage externe	DoTransfer.java	Utiliser uniquement le stockage interne (getFilesDir).
CRITIQUE	Écriture sur stockage externe	DoTransfer.java	Utiliser uniquement le stockage interne (getFilesDir).
CRITIQUE	Écriture sur stockage externe	ViewStatement.java	Utiliser uniquement le stockage interne (getFilesDir).
CRITIQUE	Écriture sur stockage externe	ViewStatement.java	Utiliser uniquement le stockage interne (getFilesDir).
ELEVE	Données sensibles dans les logs	AppInviteReferral.java	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	AppInviteReferral.java	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	zzm.java	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	zzn.java	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	GcmNetworkManager.j...	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	GoogleCloudMessagin...	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	InstanceIDListenerServ...	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	zzc.java	Supprimer tout Log contenant des données d'auth en production (Build...
CRITIQUE	Écriture sur stockage externe	zzcb.java	Utiliser uniquement le stockage interne (getFilesDir).
ELEVE	Absence d'Android Keystore	- (non détecté dans le...	Supprimer tout Log contenant des données d'auth en production (Build...

6. Session Security Scanner (Entropie / Fixation / Timeout)

Tests de securite de session cote serveur : analyse de l'entropie du Session ID (MASVS-AUTH-1), test de fixation de session (MASVS-AUTH-3), timeout d'inactivite (MASVS-AUTH-2), et invalidation post-deconnexion.

Mode : SESSION_SCANNER | Session ID : Non detecte | Findings : 1

Severite	Probleme	MASVS	Correction
INFO	Backend inaccessible		http://localhost:8888 ne répond pas.

7. Scores MASVS par Domaine

Les scores reflètent le niveau de sécurité par domaine OWASP MASVS v2. Chaque vulnérabilité déduit des points selon sa sévérité. Un score inférieur à 4 indique un risque critique sur ce domaine.

MASVS-AUTH		0/10
MASVS-STORAGE		2/10
MASVS-CRYPTO		10/10
MASVS-NETWORK		0/10
Cookie Security		10/10
Storage Security		0/10

8. Checklist de Sécurité (MASVS)

Checklist générée par IA (Claude) adaptée au type d'authentification détecté. Chaque contrôle est mappe à un chapitre OWASP MASVS pertinent. Ces points constituent le référentiel de vérification pour la revue de code.

- [] [MASVS-AUTH-1-1] Valider que chaque token JWT contient une revendication 'exp' (expiration) avec une durée de vie maximale de 15 minutes | Sévérité: CRITIQUE | CWE: 613
- [] [MASVS-AUTH-1-2] Implémenter une liste noire (blacklist) des tokens pour invalider immédiatement les tokens lors de la déconnexion | Sévérité: CRITIQUE | CWE: 613
- [] [MASVS-AUTH-1-3] Vérifier que le serveur valide la signature du JWT avec la clé secrète appropriée et rejette les tokens non signés ou mal signés | Sévérité: CRITIQUE | CWE: 347
- [] [MASVS-STORAGE-2-1] Ne jamais stocker les secrets JWT (clés privées, clés de signature) en dur dans le code source | Sévérité: CRITIQUE | CWE: 798
- [] [MASVS-STORAGE-2-2] Chiffrer tous les tokens JWT avant stockage dans SharedPreferences en utilisant EncryptedSharedPreferences | Sévérité: CRITIQUE | CWE: 312
- [] [MASVS-STORAGE-2-3] Implémenter la rotation des tokens JWT : émettre un refresh token distinct du access token avec une durée de vie plus longue | Sévérité: ELEVE | CWE: 613
- [] [MASVS-NETWORK-3-1] Enforcer HTTPS exclusivement (tlsVersion >= 1.2) pour tous les échanges impliquant des tokens JWT | Sévérité: CRITIQUE | CWE: 295
- [] [MASVS-AUTH-1-4] Vérifier que les credentials (username, password) ne sont jamais loggés ou affichés en clair dans l'application | Sévérité: ELEVE | CWE: 532
- [] [MASVS-AUTH-1-5] Implémenter une protection contre les attaques par rejeu : ajouter un nonce ou utiliser des timestamps côté serveur | Sévérité: ELEVE | CWE: 115
- [] [MASVS-CRYPTO-4-1] Remplacer le hachage MD5 par PBKDF2, bcrypt ou Argon2 pour les mots de passe | Sévérité: ELEVE | CWE: 327
- [] [MASVS-STORAGE-2-4] Nettoyer tous les tokens JWT de la mémoire lors de la déconnexion et après l'expiration | Sévérité: ELEVE |

CWE: 316

- [] [MASVS-AUTH-1-6] Valider que le token JWT n'est accepté que s'il est envoyé dans l'en-tête Authorization (Bearer scheme) et non en paramètre URL | Severite: MOYEN | CWE: 614

- [] [MASVS-NETWORK-3-2] Configurer Network Security Configuration pour bloquer tout trafic HTTP non chiffré vers les APIs sensibles | Severite: CRITIQUE | CWE: 319

9. Criteres d'Acceptation de Securite

Les criteres d'acceptation definissent les conditions que le systeme doit satisfaire pour etre considere comme securise. Ils servent de base aux tests d'acceptation, aux revues de code et aux audits de conformite MASVS.

1. Le système DOIT implémenter un endpoint de déconnexion qui invalide immédiatement le token JWT côté serveur via une blacklist.
2. Le système NE DOIT PAS stocker les identifiants ou tokens en clair dans SharedPreferences, Realm, SQLite ou la mémoire non chiffrée.
3. Le système DOIT utiliser exclusivement HTTPS 1.2+ pour tous les échanges contenant des tokens JWT ou des credentials.
4. Le système DOIT valider que chaque token JWT possède une revendication 'exp' définie et rejette tout token expiré.
5. Le système NE DOIT PAS enregistrer (Log.d, Log.e, System.out) les credentials, tokens ou données sensibles.
6. Le système DOIT implémenter une stratégie de refresh token avec un access token à courte durée de vie (< 15 min) et un refresh token à longue durée de vie.
7. Le système DOIT vérifier cryptographiquement la signature du JWT avec la clé secrète côté serveur et rejeter les tokens non signés ou mal signés.
8. Le système NE DOIT PAS utiliser d'algorithmes de hachage faibles (MD5, SHA1) pour les mots de passe ; utiliser PBKDF2, bcrypt ou Argon2.
9. Le système DOIT nettoyer tous les tokens de la mémoire lors de la déconnexion et implémenter un mécanisme de timeout de session.